

ATTAQUE PAR FORCE BRUTE (DVWA)

1. Contexte et Objectifs

Dans le cadre de l'évaluation de la sécurité des applications web, ce laboratoire pratique a pour objectif de démontrer l'exploitation d'une faille d'authentification sur l'environnement **DVWA** (Damn Vulnerable Web Application). L'intervention consiste à réaliser une attaque par **Force Brute**. L'objectif est de comprendre le comportement d'une application vulnérable pour mieux la sécuriser. Le niveau de sécurité initial de la cible est configuré sur "Low".

2. Phase de Reconnaissance (Fuite d'informations)

Avant de lancer une attaque automatisée, une analyse manuelle du comportement de l'application a été réalisée. Des tentatives de connexion erronées (`admin / pasbonnepassword`) ont permis d'observer les réponses du serveur.

Vulnerability: Brute Force

Login

Username:

Password:

Login

Welcome to the password protected area admin



Vulnerability: Brute Force

Login

Username:

Password:

Login

Username and/or password incorrect.

2.1. Inspection du code source

L'utilisation de l'outil "Inspecteur" du navigateur (DevTools) sur la page d'authentification a permis de révéler des informations structurales. L'inspection de l'avatar affiché lors d'une tentative de connexion a révélé le chemin absolu de l'image stockée sur le serveur : </DVWA/hackable/users/admin.jpg>.

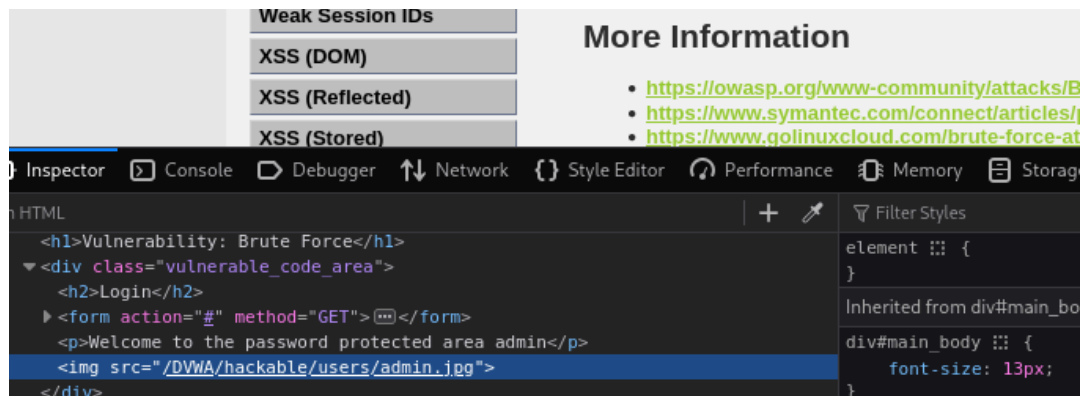


Figure 1 : Analyse du code source HTML et découverte du chemin de stockage des avatars.

2.2. Exploitation de la faille "Directory Listing"

En tronquant l'URL pour accéder directement au dossier parent (<http://localhost/DVWA/hackable/users/>), le serveur a affiché l'arborescence complète du répertoire. Cette faille de configuration (Directory Listing) a permis d'énumérer de manière exhaustive les utilisateurs valides du système : [1337](#), [admin](#), [gordonb](#), [pablo](#), et [smithy](#).

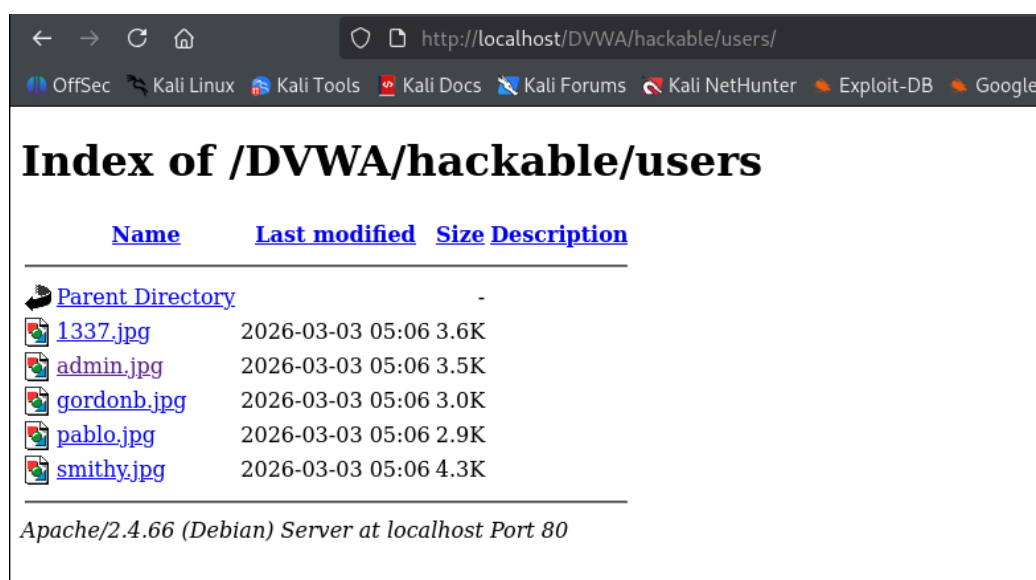


Figure 2 : Exploitation du Directory Listing pour la collecte de noms d'utilisateurs.

3. Interception du Trafic avec Burp Suite

Une fois la liste des cibles établie, le proxy d'interception **Burp Suite** a été configuré pour capturer les échanges entre le navigateur et le serveur. Une requête HTTP **POST** contenant une tentative d'authentification a été interceptée dans l'onglet "HTTP history". L'analyse brute (Raw) confirme que les identifiants transitent en clair.

22	http://localhost	POST	/DVWA/vulnerabilities/brute/	✓
24	http://localhost	POST	/DVWA/vulnerabilities/brute/	✓

Request		Response	
Pretty	Raw	Hex	Pretty
11	Upgrade-Insecure-Requests: 1		1 HTTP
12	User-Agent: Mozilla/5.0 (X11; Linux x86_64)		2 Date
	AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0		3 Serv
	Safari/537.36		4 Expi
13	Accept:		5 Cach
	text/html,application/xhtml+xml,application/xml;q=0.9,image/		6 Prag
	avif,image/webp,image/apng,*/*;q=0.8,application/signed-exch		7 Set -
	ange;v=b3;q=0.7		expi
14	Sec-Fetch-Site: same-origin		Http
15	Sec-Fetch-Mode: navigate		8 Vary
16	Sec-Fetch-User: ?1		9 Cont
17	Sec-Fetch-Dest: document		10 Keep
18	Referer: http://localhost/DVWA/vulnerabilities/brute/		11 Conn
19	Accept-Encoding: gzip, deflate, br		12 Cont
20	Cookie: security=impossible; PHPSESSID=		13
	f409bbb65201f57c7e80a603bc245a77		14 <!DO
21	Connection: keep-alive		15
22			16 <htm
23	username=admin&password=password&Login=Login&user_token=		17
	145bac627fe6b2ce36748e239f0e80ab		18 <h

Figure 3 : Interception de la requête d'authentification HTTP via le proxy Burp Suite.

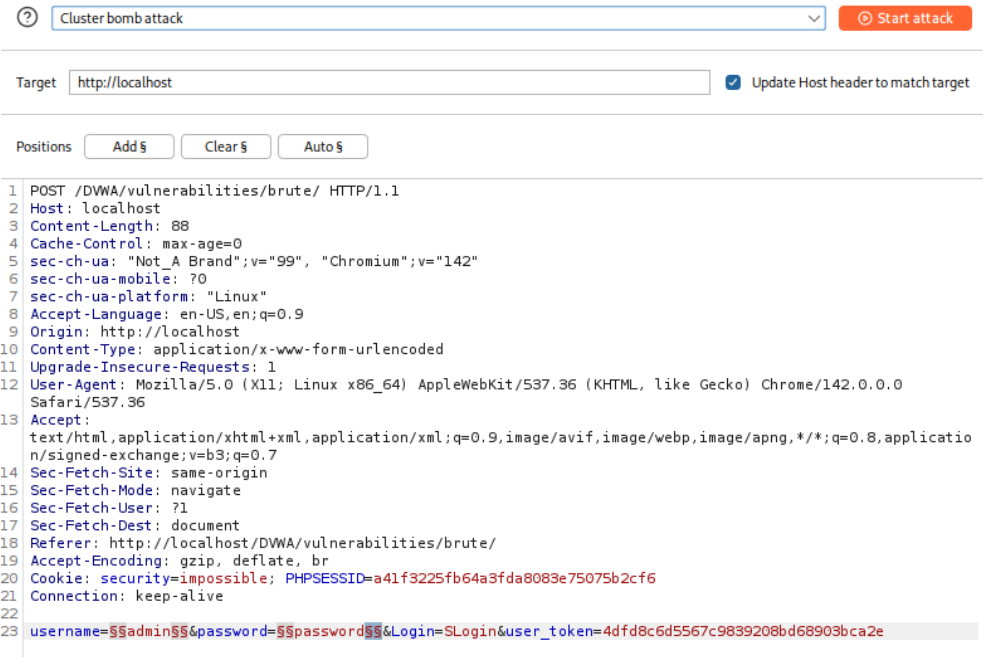
La requête a ensuite été transférée vers le module **Intruder** pour automatiser l'attaque de type Force Brute.

4. Configuration de l'Attaque (Burp Intruder)

Pour tester simultanément plusieurs mots de passe sur plusieurs utilisateurs, le mode d'attaque **Cluster Bomb** a été sélectionné. Ce mode teste toutes les combinaisons possibles entre plusieurs listes (Payloads).

4.1. Ciblage des points d'injection

Les marqueurs d'injection (§) ont été placés exclusivement sur les valeurs des paramètres **username** et **password**.



The screenshot shows the Burp Intruder configuration window. At the top, the attack mode is set to "Cluster bomb attack" with a "Start attack" button. Below, the target is "http://localhost" and the "Update Host header to match target" checkbox is checked. The "Positions" section has "Add §", "Clear §", and "Auto §" buttons. The main area displays a list of 23 payload positions for a POST request to "/DWA/vulnerabilities/brute/". The request headers and body are visible. The payload positions are marked with § symbols at the end of the "username" and "password" parameters in the request body.

```
1 POST /DWA/vulnerabilities/brute/ HTTP/1.1
2 Host: localhost
3 Content-Length: 88
4 Cache-Control: max-age=0
5 sec-ch-ua: "Not_A Brand";v="99", "Chromium";v="142"
6 sec-ch-ua-mobile: ?0
7 sec-ch-ua-platform: "Linux"
8 Accept-Language: en-US,en;q=0.9
9 Origin: http://localhost
10 Content-Type: application/x-www-form-urlencoded
11 Upgrade-Insecure-Requests: 1
12 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0
13 Safari/537.36
14 Accept:
15 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
16 Sec-Fetch-Site: same-origin
17 Sec-Fetch-Mode: navigate
18 Sec-Fetch-User: ?1
19 Sec-Fetch-Dest: document
20 Referer: http://localhost/DWA/vulnerabilities/brute/
21 Accept-Encoding: gzip, deflate, br
22 Cookie: security=impossible; PHPSESSID=a41f3225fb64a3fda8083e75075b2cf6
23 Connection: keep-alive
24 username=§§admin§§&password=§§password§§&Login=SLogin&user_token=4dfd8c6d5567c9839208bd68903bca2e
```

Figure 4 : Définition des points d'injection (Payload positions).

4.2. Configuration des Dictionnaires (Payloads)

Deux listes distinctes ont été configurées :

- **Payload 1 (Utilisateurs)** : Une liste simple (Simple list) constituée des 5 identifiants découverts lors de la phase de reconnaissance.
- **Payload 2 (Mots de passe)** : Un dictionnaire contenant des milliers de mots de passe probables (ex: issu de [rockyou.txt](#) ou d'une wordlist Kali standard).

The figure shows two side-by-side screenshots of the 'Payloads' configuration interface. Both screenshots show a 'Payloads' section with a 'Payload position' field, a 'Payload type' dropdown set to 'Simple list', a 'Payload count' field, and a 'Request count' field set to 0. Below these fields is a 'Payload configuration' section with a description: 'This payload type lets you configure a simple list of stri'. The left screenshot shows a list of 6 items: 'gordonb', 'pablo', 'smithy', '1337', and 'admin'. The right screenshot shows a list of 203,808 items, including '1Password', 'password', '123456789', '12345678', '1q2w3e4r', 'sunshine', 'aphcueggglktu', 'football', '1234567890', and 'computer'. Both screenshots have buttons for 'Paste', 'Load...', 'Remove', 'Clear', 'Deduplicate', 'Add', and 'Add from list... [Pro version only]'.

Figure 5 : Paramétrage des dictionnaires d'attaque pour le mode Cluster Bomb.

5. Exécution et Analyse des Résultats

L'attaque a été lancée. Le module Intruder a généré dynamiquement les requêtes HTTP en croisant les deux listes. L'identification des combinaisons réussies s'effectue en analysant la colonne **Length** (longueur de la réponse en octets) ou **Status code**. Une authentification réussie génère une réponse serveur d'une taille différente d'un échec (ou un code de redirection 302 différent).

The figure shows a screenshot of the 'Intruder attack of http://localhost' results table. The table has columns: Request, Payload 1, Payload 2, Status code, Response received, Error, Timeout, and Length. It shows 8 rows of results for requests 51 through 58.

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length
51	pablo	1234567890	302	4			337
52	smithy	1234567890	302	4			337
53	1337	1234567890	302	5			337
54	admin	1234567890	302	3			337
55		computer	302	6			337
56	gordonb	computer	302	5			337
57	pablo	computer	302	4			337
58	smithy	computer	302	2			337

Figure 6 : Analyse des résultats de l'attaque automatisée.